

Acme Widgets LLC – Remediation / Action Plan

Prepared by	Ronin Security Consulting – CONFIDENTIAL
Engagement	acme-ext-2026q3
Client	Acme Widgets LLC
Tester	raven
Authorized by	J. Okafor, CTO
Testing window	2026-09-01 to 2026-09-30
Report generated	2026-09-09 23:46
Overall risk rating	Critical
Findings	9 total – 2 critical, 2 high, 1 medium, 2 low, 2 info

Prepared by Ronin Security Consulting under NDA. Client distribution only.

Purpose

A strategic-level plan for closing the findings from this engagement. It maps each issue to a concrete action, an effort estimate, a suggested SLA, and an owner field for your team to assign. Use it to drive remediation tracking and to scope a verification retest.

1. Scope & Methodology

1.1 Scope

In scope

- *.acme.example
- 203.0.113.0/28

Explicitly out of scope

- mail.acme.example

Testing window: 2026-09-01 to 2026-09-30.

Rules of engagement

External black-box. No DoS. No social engineering. Credential attacks only outside 09:00-17:00 local. Report any pre-existing compromise immediately.

1.2 Methodology

Findings below were produced by: subfinder, naabu, nmap, nuclei, feroxbuster, sqlmap, nikto. Full commands and raw evidence are in the Technical Report and the engagement evidence folder.

2. Vulnerability Details – The Findings

Condensed for planning. One row per issue, ordered by priority. Full technical write-ups are in the Engineer-level report.

#	Finding	Risk	CVSS	Affected asset(s)	Confidence
1	SQL injection in GET parameter 'id' (MySQL)	CRITICAL	9.8	https://app.acme.example/item?id=1	firm
2		CRITICAL	9.8	https://app.acme.example	firm

#	Finding	Risk	CVSS	Affected asset(s)	Confidence
	Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013)				
3	Open port 6379/tcp - Redis (internet-facing)	HIGH	—	203.0.113.10:6379/tcp	confirmed
4	nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi	HIGH	—	https://legacy.acme.example/cgi-bin/status.cgi	tentative
5	Exposed Git repository at /.git/	MEDIUM	—	https://app.acme.example/.git/HEAD	confirmed
6	TLS 1.0 and 3DES ciphers offered	LOW	—	app.acme.example:443	firm
7	No Content-Security-Policy (https://app.acme.example)	LOW	—	https://app.acme.example	firm

3. Proof of Concept (PoC) & Attack Paths

3.1 SQL injection in GET parameter 'id' (MySQL) — https://app.acme.example/item?id=1

Attack path. Full DB read: dump customers + password hashes -> offline crack -> account takeover / admin. Stacked queries may allow RCE on the DB host.

Break the chain here: Parameterise every query (prepared statements). Least-privilege DB account. Add a WAF rule as an interim control. Retest with the same sqlmap command.

3.2 Apache 2.4.49 Path Traversal / RCE (CVE-2021-42013) — `https://app.acme.example`

Attack path. Unauthenticated RCE as the web user -> pivot into 203.0.113.0/28. Public exploit exists.

Break the chain here: Upgrade Apache httpd to >= 2.4.51. Disable mod_cgi/mod_cgid if unused. Restrict /cgi-bin.

3.3 Open port 6379/tcp - Redis (internet-facing) — `203.0.113.10:6379/tcp`

Attack path. Unauthenticated Redis -> read/alter cached data, write a webshell or SSH key via CONFIG SET, or gain RCE on the Redis host.

Break the chain here: Bind Redis to localhost or an internal VLAN, require AUTH + TLS, and rename/disable CONFIG. Never expose 6379 to the internet.

3.4 nikto: Shellshock RCE may be possible via /cgi-bin/status.cgi — `https://legacy.acme.example/cgi-bin/status.cgi`

Attack path. If confirmed, unauthenticated RCE on a legacy host - likely an unmonitored pivot point.

Break the chain here: Patch bash; retire the legacy CGI host or place it behind authentication and WAF.

3.5 Exposed Git repository at /.git/ — `https://app.acme.example/.git/HEAD`

Attack path. Reconstruct source + committed secrets -> authenticated access / more vulns.

Break the chain here: Deny /.git at the edge; deploy from a build artifact, not a checkout.

4. Remediation Recommendations

Prioritised action plan. Suggested SLA is measured from report delivery.

#	Action	Risk	CVSS	Asset(s)	Effort	Suggested SLA	Owner
1	Parameterise every query (prepared statements). Least-privilege DB account. Add a WAF rule as an interim control. Retest with the same sqlmap command.	CRITICAL	9.8	<code>https://app.acme.example/item?id=1</code>	Medium-High	7 days	<i>assign</i>
2	Upgrade Apache httpd to $\geq 2.4.51$. Disable <code>mod_cgi/</code> <code>mod_cgid</code> if unused. Restrict <code>/cgi-bin</code> .	CRITICAL	9.8	<code>https://app.acme.example</code>	Medium-High	7 days	<i>assign</i>
3	Bind Redis to localhost or an internal VLAN, require AUTH + TLS, and rename/disable CONFIG. Never expose 6379 to the internet.	HIGH	—	<code>203.0.113.10:6379/tcp</code>	Medium-High	30 days	<i>assign</i>
4	Patch bash; retire the legacy CGI host or place	HIGH	—	<code>https://legacy.acme.example/cgi-bin/status.cgi</code>	Medium-High	30 days	<i>assign</i>

#	Action	Risk	CVSS	Asset(s)	Effort	Suggested SLA	Owner
	it behind authentication and WAF.						
5	Deny /.git at the edge; deploy from a build artifact, not a checkout.	MEDIUM	—	<code>https://app.acme.example/.git/HEAD</code>	Low	90 days	<i>assign</i>
6	Mozilla Intermediate profile: TLS 1.2+ only, drop 3DES/RC4/EXPORT, ECDHE key exchange.	LOW	—	<code>app.acme.example:443</code>	Low	180 days	<i>assign</i>
7	Define a restrictive CSP to limit script/style/frame sources.	LOW	—	<code>https://app.acme.example</code>	Low	180 days	<i>assign</i>

Verification. Re-run the originating tool against each asset after the fix (`ronin run <tool> --engagement acme-ext-2026q3 --target <asset>`), or commission a retest. A finding is closed only when the check no longer fires.

Tracking

State	Definition
Open	Not yet started.
In progress	Fix under development or scheduled in a change window.

State	Definition
Fixed (unverified)	Change deployed; awaiting retest.
Closed	Retest confirms the originating check no longer fires.
Risk accepted	Client has formally accepted the residual risk (record who/when).

Recommended: re-run RoninSuite against each asset after remediation and diff the findings, then commission a formal retest for anything rated High or above.

Prepared by Ronin Security Consulting under NDA. Client distribution only.